暴力破解

“暴力破解”是一攻击具手段，在web攻击中，一般会使用这种手段对应用系统的认证信息进行获取。 其过程就是使用大量的认证信息在认证接口进行尝试登录，直到得到正确的结果。 为了提高效率，暴力破解一般会使用带有字典的工具来进行自动化操作。

理论上来说，大多数系统都是可以被暴力破解的，只要攻击者有足够强大的计算能力和时间，所以断定一个系统是否存在暴力破解漏洞，其条件也不是绝对的。 我们说一个web应用系统存在暴力破解漏洞，一般是指该web应用系统没有采用或者采用了比较弱的认证安全策略，导致其被暴力破解的“可能性”变的比较高。

一、暴力破解原理

1.1暴力破解漏洞成因

1、密码复杂度太低

使用的密码复杂度太低，包括长度过短、密码构成元素单一、密码具

有规律或包含个人信息等。

2、未对登录进行限制：

在登录口或是密码验证处未进行限制（例如登录时需要输入验证码、

3、限制登录频率、试错次数过多锁定账号等），可以进行无穷多次数的

密码尝试。

1.2暴力破解的危害

1、未经用户授权就可以以登陆上用户的账户进行操作

2、未经授权可以访问到某些业务系统（FTP服务、网站管理后台）

3、危害数据安全（数据库口令被破解）

4、危害服务器安全（ssh 口令被破解）

1.3一般攻击步骤

1、 寻找可能能进行暴力破解的服务或登录口

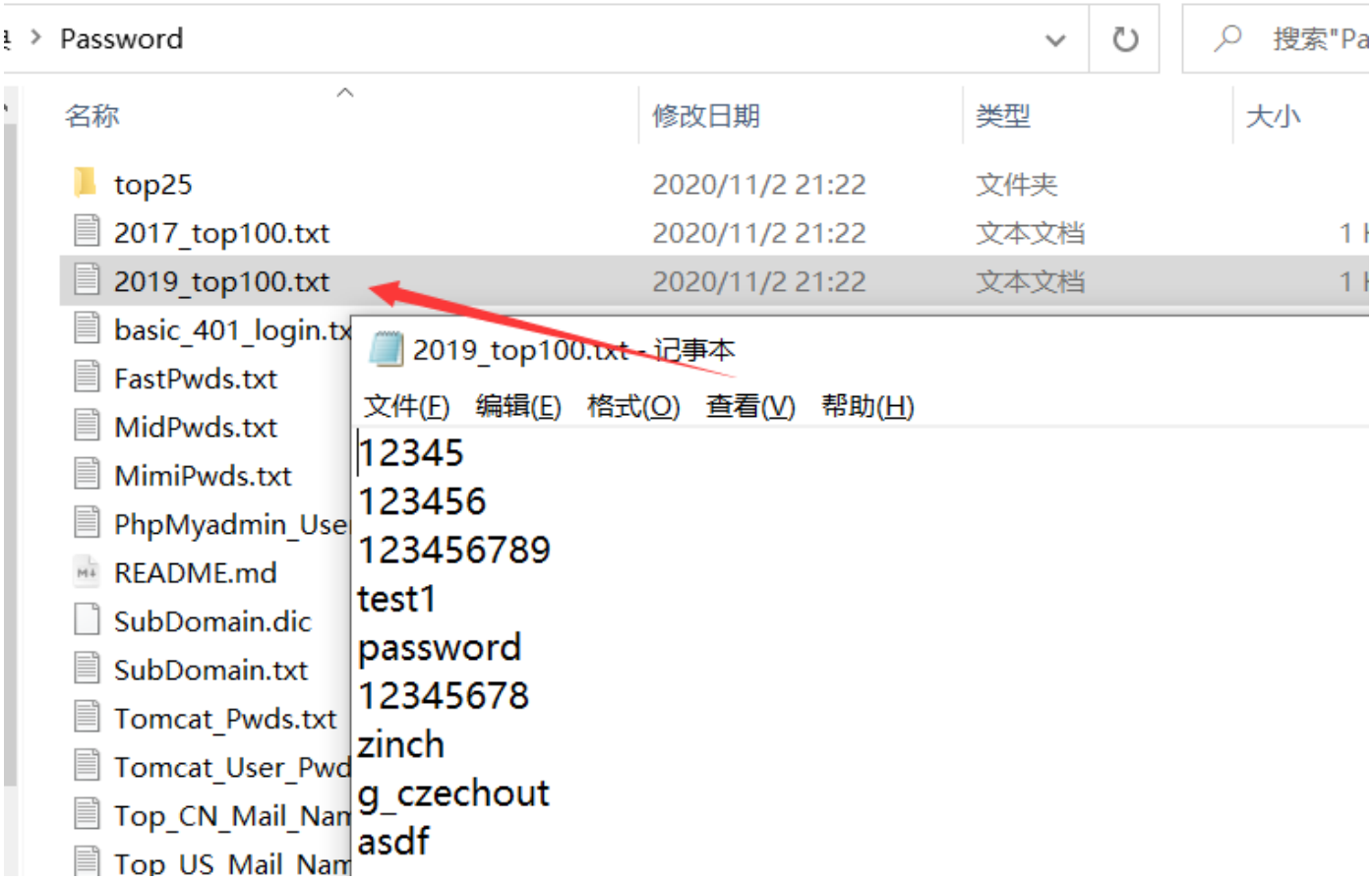
2、 进行简单登录测试判断是否有防御机制以及能否进行暴力破解

3、 若是服务的爆破，使用 Hydra等工具进行暴力破解

4、 若是web页面的爆破，除了可以使用Hydra之外，也可以使用 burp进行暴力破解

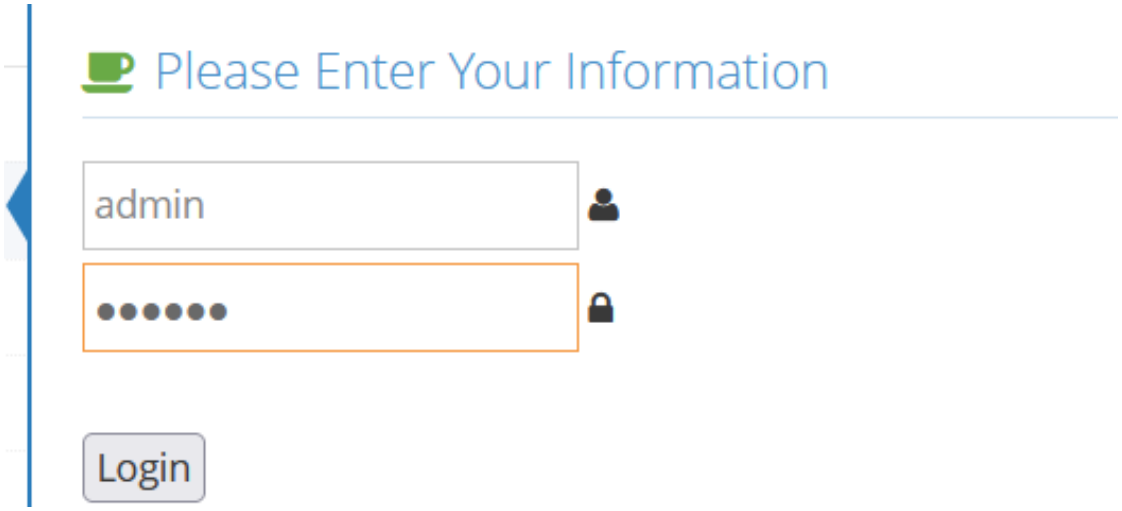
二、弱口令爆破

是指使用字典文件进行爆破，字典多为经验积累其中是一些常见的字符组合。



2.1登录认证流程（了解）

1. 用户填写表单 admin / 123456

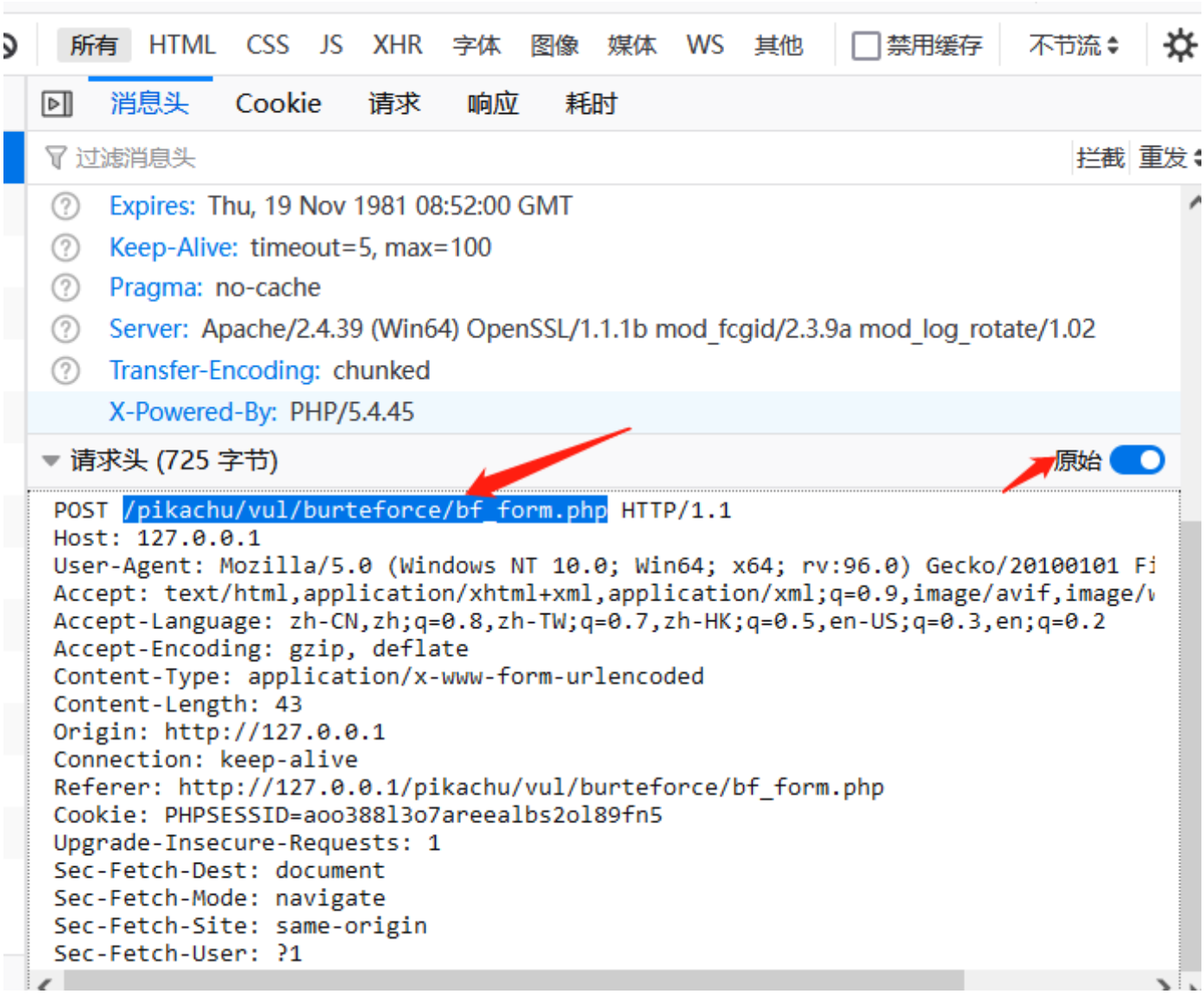


2. 用户点击 “login” 就会发送一个数据包到网站后台的某个地方

数据包 admin / 123456



某个地方 /pikachu/vul/burteforce/bf_form.php



bf_

3. bf_from.php 这个文件里的代码会验证 你提交的 表单里 账号密码是否正确

如果正确，就给你返回登陆成功应该看到的页面 如果错误就拒绝你登录。

简单登陆认证模型

`login.php`

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Document</title>
</head>
<body>
    <form action="login.php" method="POST">
    账号: <input type="text" name="username">
    <br/>
    密码: <input type="text" name="password">
    <br/>
    <button type="submit">登陆</button>
    </form>

</body>
</html>
<?php
$username = $_POST['username'];
$password = $_POST['password'];
echo $username."/".$password."\r\n";
if($username == 'admin' && $password == '123456'){
    echo "欢迎您登陆成功! ";
}else {
    echo "账号或密码错误! ";
}
?>
```

三、靶场练习（操作重点）

Pikachu

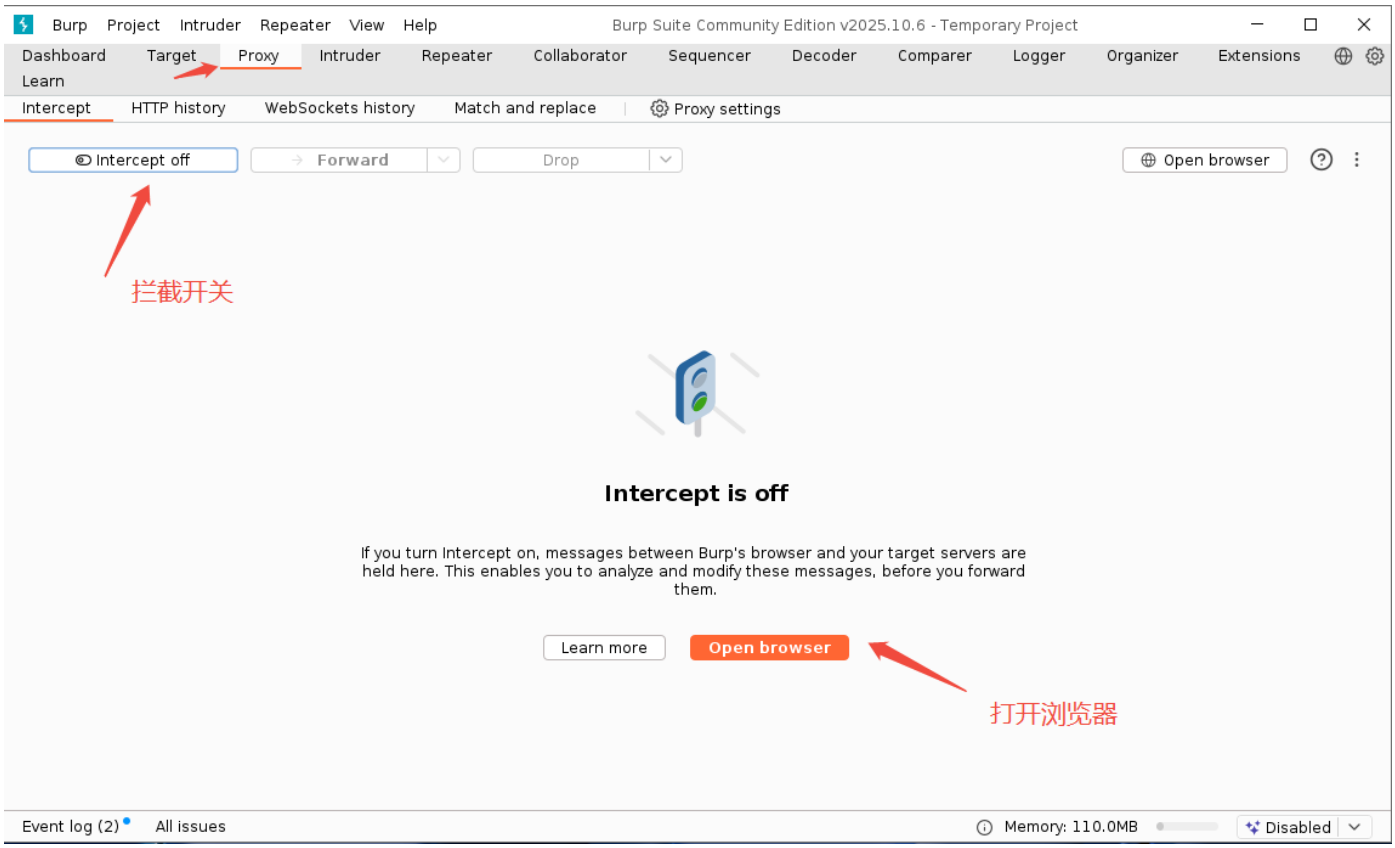
在线靶场 http://vulfocus.cn/ 搜索启动 `pikachu`

```
pikachu靶场已有的账号密码:

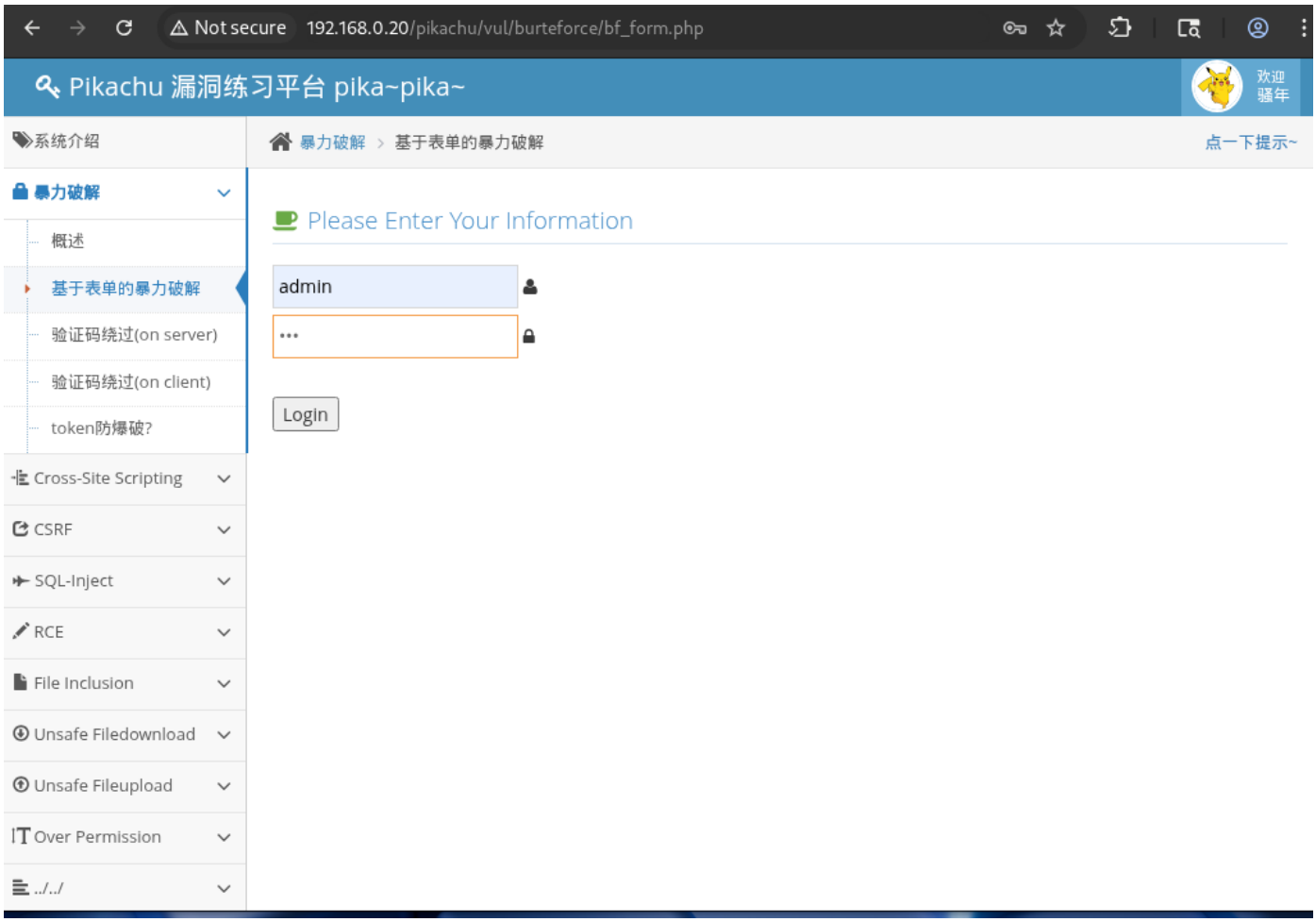
|  1 | admin  /  123456
|  2 | pikachu / 000000
|  3 | test   /  abc123
```

3.1 基于表单的暴力破解

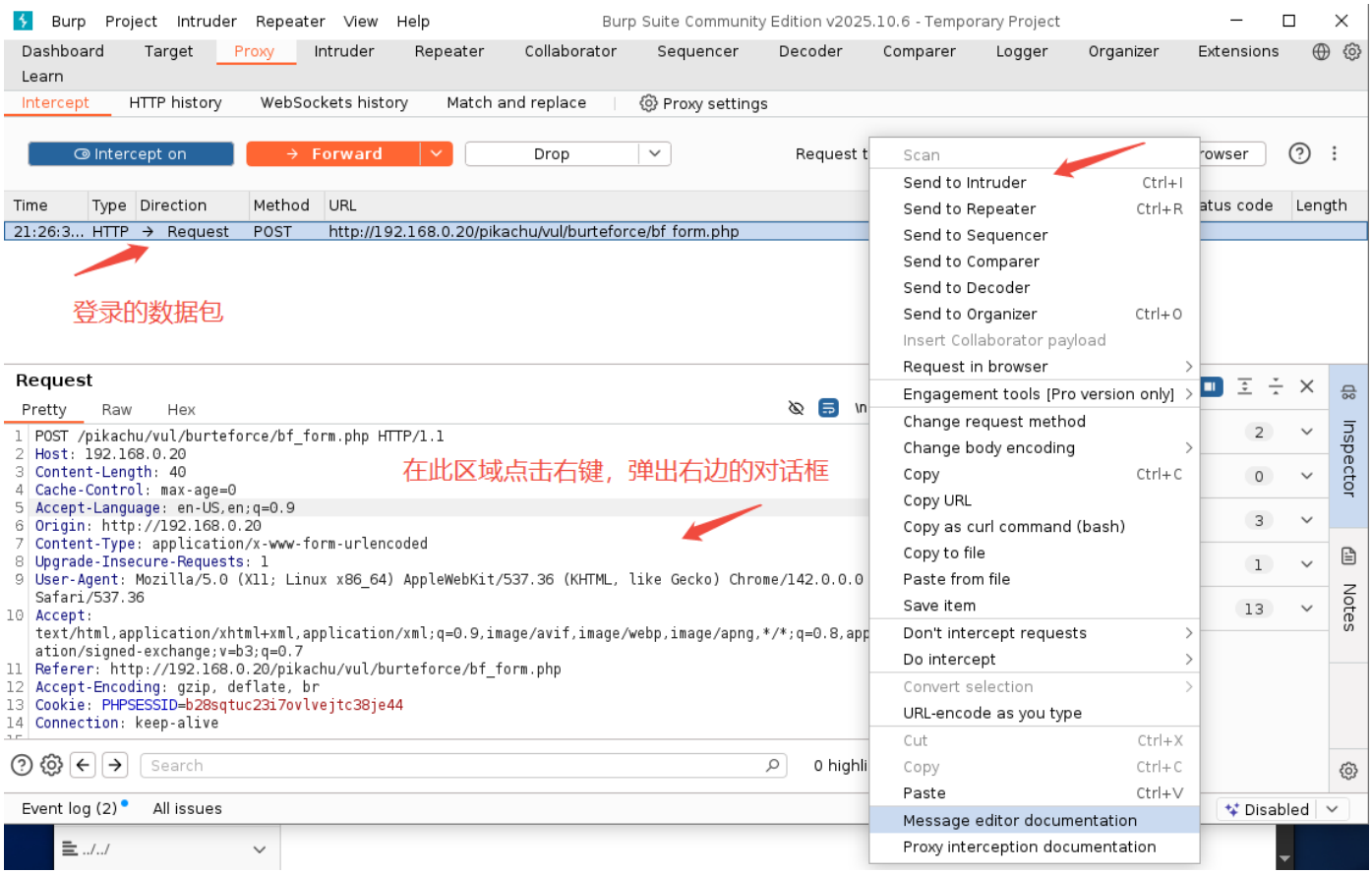
1、打开 kali 中的 burpsuite 软件。点击 proxy 界面，在 burpsuite 中 open brower （或者打开火狐或者谷歌浏览器），同时打开 intercept 拦截开关。



2、在　browser 中输入靶场的网址。这里的账号密码就是需要破解的地方。首先我们先随便输入一下账号和密码，然后点击 login。

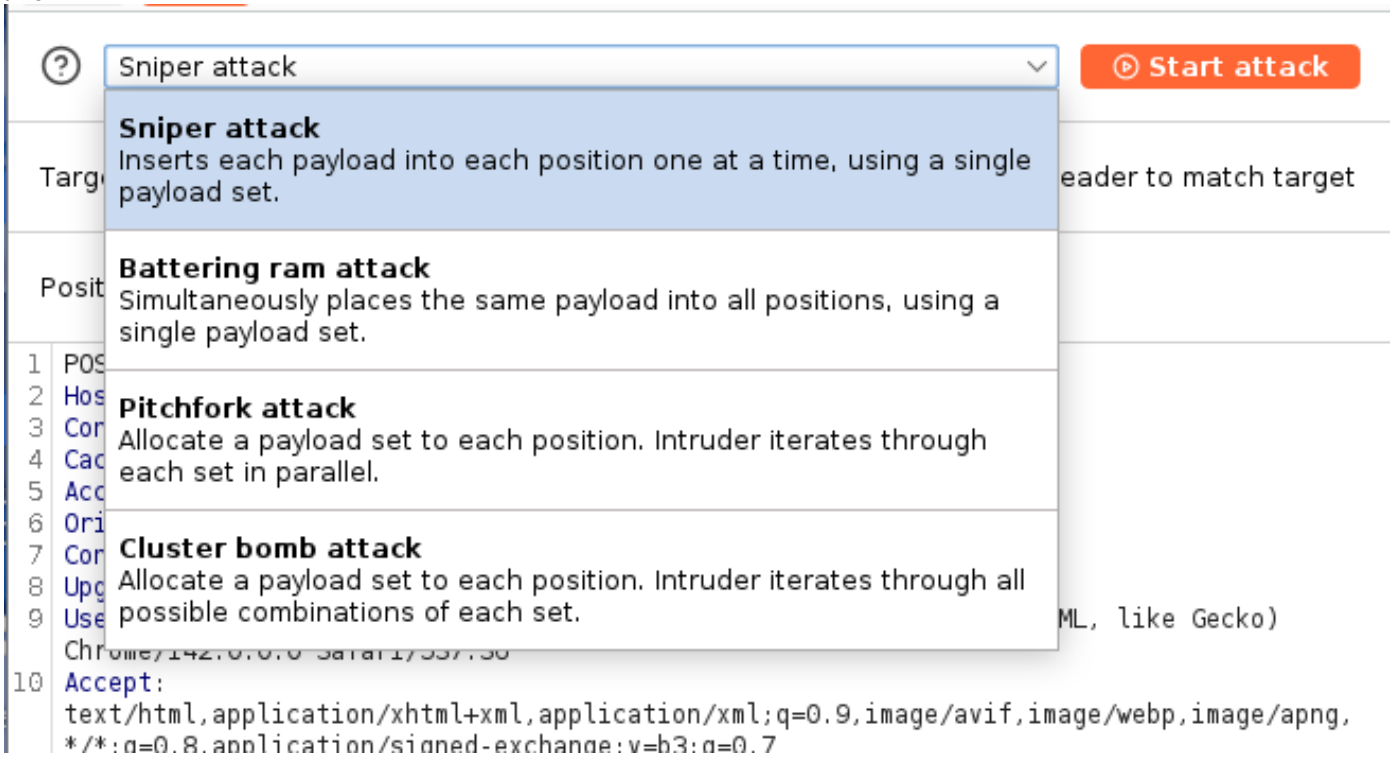


3、此时，在 burpsuite 中就拦截到了这个登录的数据包。选中该数据包，将此数据包 send to intruder。



4、点击 intruder，根据实际需求，选择相关方式，分别为：

这四种攻击模式是 Burp Suite Intruder 模块的核心功能，用于自动化测试 Web 应用的安全性，它们在处理 payload 位置和组合方式上有着本质区别，适用于不同的测试场景：



Sniper attack（狙击手攻击）
这是最基础的攻击模式，它会将一个 payload 集合中的每个 payload 依次插入到每一个定义好的 payload 位置中，每次只替换一个位置，其他位置保持不变。
它适用于对单个参数进行暴力破解或模糊测试，比如测试登录框的用户名或密码字段，或者测试某个 URL 参数是否存在 SQL 注入。

Battering ram attack（攻城锤攻击）
这种模式会将同一个 payload 同时插入到所有定义好的 payload 位置中。也就是说，它会遍历 payload 集合，每次取出一个 payload，然后把这个 payload 同时填入所有位置。
它适用于测试多个参数需要同时满足相同条件的场景，比如测试多个输入框是否都对某个特殊字符敏感，或者测试多个参数是否都存在相同的注入点。

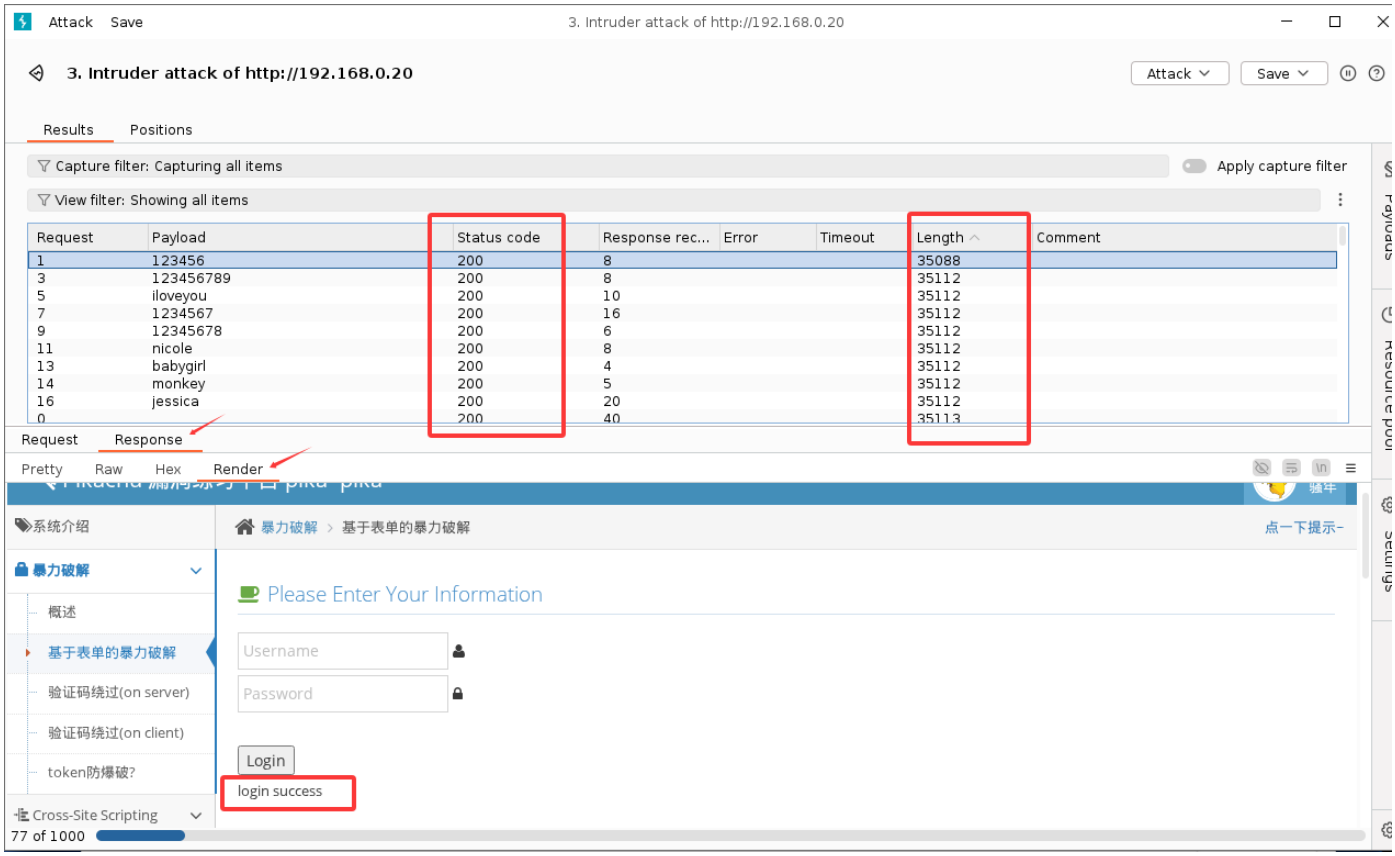
Pitchfork attack（叉子攻击）
这种模式需要多个 payload 集合，每个 payload 位置对应一个 payload 集合。它会并行地从每个集合中取出一个 payload，然后将它们分别填入对应的 payload 位置。
它适用于测试多个参数之间存在关联的场景，比如测试用户名和密码的组合，或者测试多个相关联的参数是否能触发特定的逻辑错误。

Cluster bomb attack（集束炸弹攻击）
这种模式也需要多个 payload 集合，每个 payload 位置对应一个 payload 集合。与 Pitchfork 不同的是，它会遍历所有可能的组合，即第一个集合的每个 payload 会与第二个集合的每个 payload 组合，依此类推。
它适用于测试多个参数之间所有可能的组合，比如测试用户名和密码的所有可能组合，或者测试多个参数的所有可能输入是否能触发漏洞。这种模式生成的请求量最大，测试最全面，但耗时也最长。

PS:这里我们做一个前提假设，假如我们已经知道该登录接口的用户名为 admin，这里仅需要破解该用户的密码，所以我们此时选择 sniper attack 模式。

在密码的数据上添加标签，然后倒入密码文本，点击 start attack。进行破解。

5、查看具体情况，可以根据 status code 和 length 的情况进行初步的查看，code 为 200，长度明显与其他不一致的可以重点查看，最后通过查看 response 的 render 具体查看返回的情况。



通过上图，可以看出 该网站的登录接口，用户名为 admin，密码为 12346